

1 / 6

En esta vista, el conector ha pasado de ser un canal simple de tipo *Request/Reply (HTTP)* a un **Secure Request/Reply (HTTPS/TLS 1.2+)**. Traefik actúa como el "Punto de Terminación TLS", lo que significa que el canal seguro se cierra en la frontera del sistema, permitiendo que el tráfico interno hacia los microservicios fluya en una red privada protegida.

2. Technical Guide (Guía Técnica)

2.1. Description of the pattern and its purpose

El **Secure Channel Pattern** tiene como propósito establecer un túnel de comunicación cifrado entre dos entidades para garantizar que la información sensible no pueda ser interceptada ni modificada por terceros. Su implementación asegura que los extremos de la comunicación estén plenamente identificados mediante certificados digitales, mitigando ataques de *Man-in-the-Middle* (MitM).

2.2. Quality scenario addressed

Escenario de Autenticación:

"Cuando un usuario envía sus credenciales (correo electrónico y contraseña) desde la CLI o la Web hacia el sistema Fitbeat para iniciar sesión, los datos deben viajar cifrados en un canal seguro. El sistema debe garantizar la **confidencialidad** para que ningún atacante con acceso a la red pueda leer las credenciales en texto plano, y la **integridad** para asegurar que la solicitud de inicio de sesión no sea alterada en tránsito."

2.3. Steps followed to implement the pattern

Paso 0: Preparación de Herramientas

- **OpenSSL:** Instalado mediante Git Bash (Windows) para actuar como nuestra fábrica de certificados.
- **Librerías:** No se requirieron librerías externas adicionales, aprovechando la capacidad nativa de **Traefik** como Reverse Proxy para la gestión de TLS.

Paso 1: Definición del Escenario de Calidad

Se identificó el proceso de login como el punto más crítico. El canal seguro debe proteger el envío de credenciales hacia el **auth-service** a través del Gateway.

Paso 2: Creación de la Entidad Certificadora (CA) de Fitbeat

1. Se creó el directorio de trabajo:

```
mkdir laboratory-5 && cd laboratory-5
```

2. **Generación de la Llave Privada de la CA:**

```
openssl genrsa -out fitbeat-ca.key 2048
```

3. Generación del Certificado Raíz (Root Certificate):

```
MSYS_NO_PATHCONV=1 openssl req -x509 -new -nodes -key fitbeat-ca.key -sha256 -days 365 \
-out fitbeat-ca.crt -subj "/CN=Fitbeat-CA/O=Universidad Nacional/C=CO"
```

Configuración: En "Common Name", se asignó **Fitbeat Authority**.

Paso 3: Generación del Certificado para el "Secure Channel"

1. Generación de la llave privada del servidor:

```
openssl genrsa -out fitbeat-server.key 2048
```

2. Creación del CSR (Certificate Signing Request):

El certificado debe incluir SAN para que el navegador/Postman lo acepten mejor:

```
MSYS_NO_PATHCONV=1 openssl req -new -key fitbeat-server.key -out fitbeat-server.csr \
-subj "/CN=localhost/O=Fitbeat-Project/C=CO"
-addext "subjectAltName=DNS:localhost,IP:127.0.0.1"
```

IMPORTANTE: En "Common Name", se definió **localhost**.

3. Firma del certificado con la CA:

```
openssl x509 -req -in fitbeat-server.csr \
-CA fitbeat-ca.crt -CAkey fitbeat-ca.key \
-CAcreateserial -out fitbeat-server.crt -days 365 -sha256
-copy_extensions copyall
```

2.4. Configuration and code snippets used

A. Configuración de Infraestructura (**docker-compose.yml**)

Se inyectaron los certificados y se habilitó el puerto 443 para el tráfico HTTPS.

```
ports:
  - "8090:80"    # HTTP Inseguro (Para pruebas de pentest)
  - "443:443"    # HTTPS Seguro (Canal establecido)
volumes:
  - ./laboratory-5/certs:/etc/traefik/certs:ro # Certificados en modo solo lectura
```

B. Configuración del Canal Seguro (traefik/dynamic.yml)

```
http:
  routers:
    auth-http:
      entryPoints:
        - web
      rule: "PathPrefix(`/api/auth`) || PathPrefix(`/auth`) || PathPrefix(`/users`)"
      service: auth-svc

    auth-https:
      entryPoints:
        - websecure
      rule: "PathPrefix(`/api/auth`) || PathPrefix(`/auth`) || PathPrefix(`/users`)"
      service: auth-svc
      tls: {}

tls:
  certificates:
    - certFile: "/etc/traefik/certs/fitbeat-server.crt"
      keyFile: "/etc/traefik/certs/fitbeat-server.key"
  options:
    default:
      minVersion: VersionTLS12
      cipherSuites:
        - TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256
        - TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384
```

2.5. Results and improvements observed (Pentest con Wireshark)

Se realizó una comparación técnica interceptando el tráfico durante el proceso de autenticación:

1. **Sin Canal Seguro (Puerto 8090):** Al capturar el tráfico HTTP, se observó el paquete POST de login con el JSON de credenciales (`email` y `password`) en texto plano, totalmente legible para cualquier interceptor.

```

Wireshark · Seguir secuencia TCP (tcp.stream eq 5) · Adapter for loopback traffic capture

POST /api/auth/login%0A%0A HTTP/1.1
Authorization: bnDc9wd9wnJbznRBdhrUB3M7Uy42Xwt4fpXEi2daQspEQapPkkCAfNBByHXk8FkXp
Content-Type: application/json
User-Agent: PostmanRuntime/7.53.0
Accept: */*
Cache-Control: no-cache
Postman-Token: 6b291544-0b86-47b2-887b-af3acb382239
Host: localhost:8090
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Content-Length: 74

{
  "email": "hidew35754@bezill.com",
  "password": "$3cur3_p@55w0rd"
}

```

2. **Con Canal Seguro (Puerto 443):** Al repetir el proceso vía HTTPS, Wireshark solo capturó el *TLS Handshake*. Toda la información de autenticación viajó cifrada bajo el protocolo TLS 1.2, resultando en datos ininteligibles (gibberish) para el atacante.

```

Wireshark · Seguir secuencia TCP (tcp.stream eq 1) · Adapter for loopback traffic capture

.....Ek|.L.<.....,FW(^.1.u3..1.. ..8.R..h.A..?.WdAh5c.^ =|.s...$...../..+.0..'. ..
.
...../5..... localhost.....
.....#...
.....3.&$. 2G..t.&.Tz....."@.~.-.....p.-.....+.....
...z...v..oq.....JN...[1..._..KH.....(|.....8.R..h.A..?.WdAh5c.^ =|.s.....+.....3.$... .8.T.Q.i1&-
Q...D...z.....>.....2.....=..7'..V.y.....L....)\7o^..q+..S./|8..k\.. B.oV..wK.c...../7...
.nJE4.m.s.b.....V.....'x~ ..7.2.....U..W.I.....`..8%.....>Kv.....Y.)E.....5_sL..Yo..C.I.&.....5.q.....w.q5.....
J.....HT.L.....".....M.....d*8".....r.iO..~z...
Qf**..d.FdQ.(.....J..S.(.....V..6,.$...
.c..W....}.&...{..K.,.B.8.Q,{U1[#..7W6. e..P...Gf..)W.....~2.....3.Vu.....~%7..m..s ct+.g..R...n>..h+...#...).2
.. ^PN..r.n.r..S..2..t..f.v`.....:
Cz.6<.N..(.|:~.-}.Dv)r.....S.....n.....$%.w.rM..P.q[...I=)....fE...Q.....6...8..0.O.T.2.X.U..U.{h..
...=@X$.e.#?.n...|-[.u#..B4.8J6.;....[.....g.....H.....e.g..L.z.4L_o0.....H.;.....b6X@K...6.eJ0.X&C..f
...v~<..bK..P..w...S.=..P.12$.X.;x.._f.....C[f>.#zJN.^6.....G.lf..M...-.....Z...1...*O.....,F.[..0+9.=.w<S..
...L...c..i...q.....o...>..].).O.....-e.%..T.....9)...S.....ebj..v.....k8R.0.oTS..kaY...m..4...x....jM...LVu..
nA..w.s.O.$#...2...P^..}.dL3>z.4...A.v1.....[...#.....6.Z(.$.U.WF... .._..D28....<..yJ....s.S..}:.f.2.I&
...a...{..@..s/V.?.Dwy;C8h...f.....<..J.....fk.....Q.....hM",9..8....i.Q.U0..+.....q...z.....F.....+...K
g.H....d K.oy.U+K.8..s..w. H.K.J.;I9...?:cbA...#...b...)%...+..g..J<...n[Q..."...KF..{b..4)..rB>.P.....5H!..
...Va.....od.....x>I
..XC..(i.^..Fr...f[.Q..U.y.....@...%.."[.tO%..z..Ljz%.....9_..&.^;@e...qS..Z?*.....7...X.m.`.....{p...
5w..9.....;;>>.....[.XYu*XQ.....9.....',].....7..Y..>
.....5...X..7.KifJ3f..Q.78;.....H..~.z.z..W.5.M...y.".....1K.)e..9*. @z.....(..E....E..E.,
. j.].....n...r..~.....YbQ7:}tr....|...R[...-..H<J...EFn~!3j.o....v=.r...T\..iZ.[.M(s..a..K.....S..Fw)....
.....le.v.y..Ai/q.....G..o.....E.....R./$.X."...D...5...$X..&..x>j...X...m.y.?..Tg.l.m.$...u...?...
m...O&V.3.
.VZ.=.....<.^..o..C. ....Z.M.wx.b.....a(..Z...-,t.C.....8 qrGZ..~/...|'..U`.....uVR..1...K.."1"%<...*
.L..@1.....|...'.<..k...0c.....[qR..-..O[V..-s.....Tx.....7..d..QIy{ ..}.f..(..
.....~.....@..Wh..5..R#?'JsOi..r%.X.1...@..^..0]..B).....;...G....%.....v7..>.%...1..>v!.ZJ+.65..L..B.]+..IV
.N.K...y.)...@i..h.).....K.H.j.,.,[4 k...@R.b.....]eb.Y

```

2.6. Recommendations for other teams

- **Uso de `MSYS_NO_PATHCONV`:** Al trabajar en Windows con Git Bash, es vital usar esta variable de entorno al generar el CSR para evitar que las barras diagonales del parámetro `-subj` sean convertidas en rutas de archivos:

```
MSYS_NO_PATHCONV=1 openssl req ...
```

- **Terminación TLS vs End-to-End:** En entornos internos altamente sensibles, se recomienda llevar el canal seguro hasta el microservicio, aunque para la mayoría de arquitecturas de red privada, la terminación en el Gateway es el equilibrio óptimo entre seguridad y rendimiento.
- **Volúmenes Solo Lectura:** Siempre montar los certificados con el sufijo `:ro` para evitar que procesos dentro del contenedor puedan manipular la identidad del servidor.